

Mapeo de preguntas de la Encuesta SSVC a requisitos normativos y marcos de referencia

La tabla siguiente relaciona, a alto nivel, los bloques y tipos de preguntas de la encuesta con requisitos típicos de NIS2, buenas prácticas europeas, documentación SSVC y orientaciones de organismos oficiales y estándares. [web:24][web:30][web:33][web:39][web:19][web:6]

Nota: el mapeo es orientativo y no sustituye a un análisis jurídico o de cumplimiento detallado.

Bloque / Pregunta	Tema principal	Referente normativo / marco	Relación principal
0.x	Identificación básica de la organización	NIS2 (clasificación entidades esenciales / importantes) [web:33] [web:39]	Permite segmentar obligaciones y comparabilidad sectorial
1.1-1.4	Política y gobernanza de gestión de vulnerabilidades	NIS2 – gestión de riesgos, gobernanza, responsabilidad de la dirección [web:33] [web:39]; ISO 27001 A.5, A.8	Exigen políticas formales, integración en la gestión de riesgos y supervisión de la dirección
1.5	Formación de la alta dirección	NIS2 – responsabilidad personal, capacitación de la dirección [web:39][web:36]	La dirección debe poder comprender y valorar las decisiones de riesgo, incluidas vulnerabilidades
2.1-2.4	Inventario y criticidad de activos	NIS2 – descubrimiento de activos y gestión de riesgos [web:33]; NIST CSF ID.AM	La priorización debe apoyarse en un inventario actualizado y categorización de activos críticos
3.1	Frecuencia de escaneos	NIS2 – supervisión continua, detección de vulnerabilidades [web:33][web:35]	Alineado con prácticas de monitorización continua y reducción del tiempo de exposición
3.2-3.4	Uso de KEV, Vulnrichment, EPSS	Prácticas CISA (KEV, Vulnrichment) [web:19][web:22] [web:25]; investigación EPSS [web:23][web:20]	NIS2 pide priorización basada en riesgo, lo que incluye explotación real y contexto de amenazas
4.1-4.5	Adopción de SSVC	Documentación CERT/CC SSVC [web:24][web:30] [web:19][web:37]; prácticas CISA [web:6] [web:19]	SSVC es uno de los marcos recomendados para priorización basada en impacto y explotación
5.1-5.6	Puntos de decisión SSVC	SSVC – explotación, impacto técnico, impacto misión, exposición [web:24] [web:30]; KEV/Vulnrichment [web:22][web:25] [web:19]	Estos atributos materializan el requisito de priorizar en función de riesgo real

6.1-6.5	De decisión a acción (SLA, backlog, reporting)	NIS2 – tiempos de respuesta, reporting, evidencia de acciones [web:33][web:36]; CISA BOD 22-01 [web:30]	SLA por criticidad y documentación de decisiones son esenciales para demostrar cumplimiento
7.1-7.3	Métricas (MTTD, MTTR, % en plazo)	Métricas de vulnerabilidades recomendadas en informes industriales [web:32][web:27] [web:35][web:41]; NIS2 – reporting [web:33]	Las métricas permiten evidenciar el desempeño del programa de vulnerabilidades
7.4	Correlación decisiones– incidentes	Estudios empíricos CVSS/EPSS/SSVC [web:16][web:20]; NIS2 – mejora continua [web:33]	La revisión de incidentes sirve para ajustar el modelo de priorización y demostrar eficacia
7.5-7.6	IGM y ROI	Informes de estado de la gestión de vulnerabilidades [web:27][web:38] [web:32][web:41]	Ayudan a conectar esfuerzos de seguridad con resultados de negocio y cumplimiento
8.1-8.4	Relación directa con NIS2	NIS2 – alcance, obligaciones específicas, reporting y evidencias [web:33] [web:39][web:36]	Evalúan el grado de preparación de la organización ante supervisión y auditorías
9.1-9.3	Automatización y estándares (JSON SSVC, CSAF, ML)	SSVC – esquemas de datos, CVE/CSAF [web:19][web:24] [web:28]; prácticas industriales [web:18] [web:8][web:21] [web:17]	La automatización es clave para escalar SSVC y cumplir plazos de respuesta
10.1-10.5	Cultura, apoyo y prioridades	NIS2 – liderazgo y responsabilidad [web:39][web:36]; informes de madurez [web:27][web:38]	Sin cultura y prioridades claras, el cumplimiento se convierte en ejercicio cosmético

Este mapeo puede ampliarse con referencias específicas al derecho nacional (transposición de NIS2, requisitos sectoriales, etc.) según el país y sector.